



Universidad
Internacional
de Valencia

Máster en Ciberseguridad
Hacking Ético

Carlos E. Noboa Guerrero

24 mayo 2026

De:
 Planeta Formación y Universidades

Tabla de contenido

1. Introducción y Perfil del Objetivo 3

1.1. Identificación de la Organización 3

1.2. Foco de Negocio 3

1.3. Resumen de Presencia Digital..... 3

2. Proceso de Investigación (Marco Metodológico) 3

2.1. OSINT Framework..... 3

2.2. Identificación de Redes, Dominios y Subdominios..... 5

3. Personas y Redes Sociales (OSINT Orientada a Humanos)..... 11

3.1. Identificación de Datos Sensibles 11

4. Conclusiones y Plan de Acción (Transición a la Fase Activa)..... 13

4.1. Síntesis del Reconocimiento Pasivo y Matriz de Validaciones..... 13

4.2. Plan de Acción Estratégico y Vectores de Explotación 14

5. Bibliografía 19

Ilustración 1. OSINT Framework Ilustración4

Ilustración 2. Whois consultas a bases de datos de los registradores de dominios6

Ilustración 3.Consultas a los servidores de nombres DNS (Dig) Ilustración.7

Ilustración 4. Enumeración de subdominios.....8

Ilustración 5. Identificación pasiva de tecnologías web (WHATWEB)9

Ilustración 6. Reverse IP Lookup (hacker target)..... 10

Ilustración 7. Bypass / Fuga DNS (Dig)..... 10

Ilustración 8. Validez temporal del ecosistema transaccional api y payments (crt.sh)..... 10

Ilustración 9. Superficie de ataque identificada 11

Ilustración 10. Estructura Organizacional de Madrid HiFi 12

Ilustración 11. Fugas de Información Técnica mediante Ingeniería Social Pasiva 13

Tabla 1. Matriz de Validación del Reconocimiento Pasivo 13

Tabla 2. Matriz de Ejecución y Plan de Acción 14

Tabla 3. Personal y Estructura Organizacional 15

Tabla 4. Matriz de Ejecución y Plan de Acción (Vectores) 17

1. Introducción y Perfil del Objetivo

1.1. Identificación de la Organización

- **Nombre de la empresa:** Madrid HiFi.
- **Sector comercial:** Comercio minorista especializado en la venta online de sonido e iluminación profesional.

1.2. Foco de Negocio

- **Actividades principales:** La organización se dedica a la comercialización de instrumentos musicales, equipos para DJ (mesas, controladores), altavoces, etapas de potencia y amplificadores. Cuenta con una trayectoria de 55 años en el mercado.
- **Activos críticos:**
 - **Plataforma E-commerce:** El dominio *madridhifi.com* es el núcleo de su operación de ventas.
 - **Infraestructura de Red:** Utiliza servicios de Cloudflare para la gestión de tráfico y seguridad.
 - **Gestión de Datos:** Manejo de bases de datos de clientes y sistemas de pago integrados en su tienda online.

1.3. Resumen de Presencia Digital

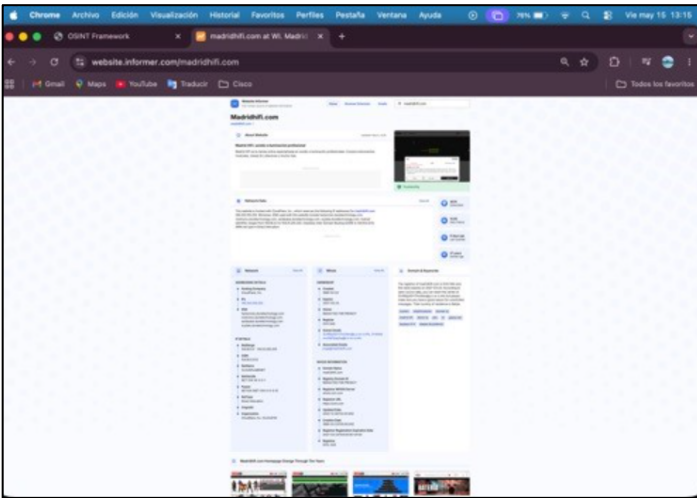
- **Dominio y Antigüedad:** El dominio principal fue creado el 23 de marzo de 1999, lo que representa una presencia web consolidada de 27 años.
- **Infraestructura Tecnológica:**
 - **Hosting:** Alojado bajo la infraestructura de **OVH** (IP 149.202.105.250)
 - **Servicios de DNS:** Gestionados a través de *dunetechnology.com*.
 - **Registrador:** El dominio está registrado a través de OVH.
- **Alcance y Tráfico:** Posee un ranking global de 467K, con un promedio de 10.6K visitantes diarios.
- **Identidad en la Red:** Además del dominio *.com*, se identifica relación con el dominio *madridhifi.net*. Su huella digital incluye la exposición de correos electrónicos corporativos asociados a la gestión del dominio y la organización.

2. Proceso de Investigación (Marco Metodológico)

2.1. OSINT Framework

Se utilizó la plataforma *OSINT Framework* como guía para identificar fuentes de información pública de forma estructurada. Dentro del framework, se navegó a través de la categoría *Domain Name*, seleccionando la subcategoría *WHOIS Records* para localizar bases de datos de registro de dominios. Se seleccionó específicamente el recurso *Website Informer* para centralizar la búsqueda de datos técnicos, de propiedad y de tráfico en un solo informe.

2.1.1. Ejecución del Reconocimiento de Dominio



Se procedió a ingresar el dominio objetivo *madridhifi.com* en la interfaz de búsqueda de *website.informer.com*. La herramienta procesó la consulta y generó un reporte detallado que incluye la infraestructura de red, los datos de registro (WHOIS) y las estadísticas de tráfico.

2.1.2. Extracción de Hallazgos Clave

A través de este proceso de reconocimiento pasivo, se logró extraer la siguiente información técnica crítica:

- **Infraestructura de Red y Enrutamiento:** Se identificó que la plataforma de *madridhifi.com* opera con IP 104.20.37.221 corresponde al proxy de Cloudflare (capa perimetral visible públicamente), mientras que 149.202.105.250 es la IP real del servidor de origen en OVH, oculta pero identificada mediante triangulación pasiva.
- **Registros de DNS:** Se localizaron los servidores de nombres autoritativos (Nameservers) asignados al dominio, los cuales apuntan a nodos personalizados bajo la entidad *dunetechnology.com* (harkonnen, nostromo, sardaukar y scytale), delegando la resolución técnica del direccionamiento web en coexistencia con los servicios de protección perimetral.
- **Propiedad y Registro:** Su registro original, data del 23 de marzo de 1999 y con fecha de expiración programada para el 23 de marzo de 2027. Longevidad técnica de 27 años en el sector.
- **Análisis de Superficie Web:** Se identifica la presencia activa de la solución Cookiebot (Usercentrics) para la automatización de políticas de privacidad, garantizando de manera visible los requisitos normativos del RGPD en su portal de cara al usuario.

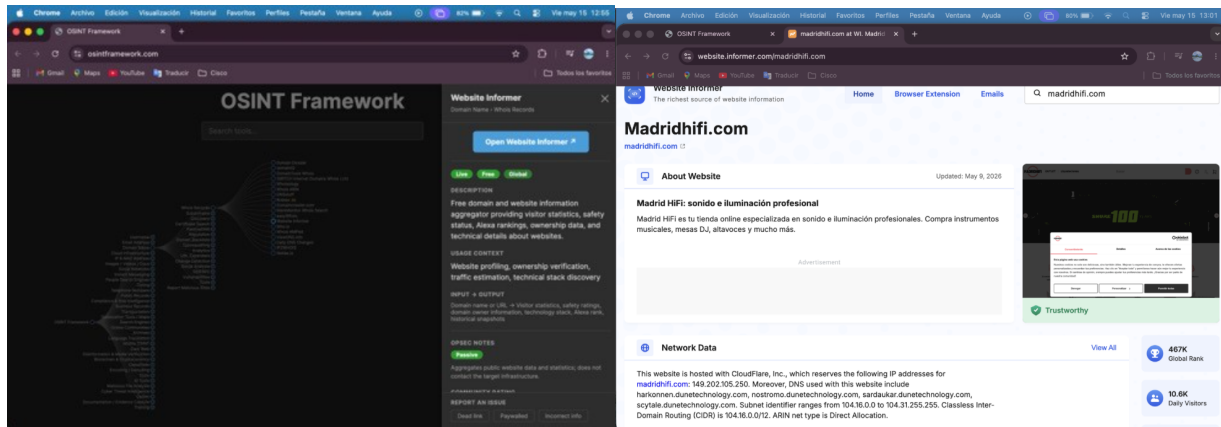


Ilustración 1. OSINT Framework Ilustración

2.2. Identificación de Redes, Dominios y Subdominios

Para obtener los datos técnicos analizados (como la infraestructura de OVH y los servidores DNS de *dunetechnology.com*), se utilizan las siguientes herramientas de reconocimiento pasivo:

2.2.1 Recolección de Atributos de Registro y Propiedad mediante Whois

Se usó whois que realiza consultas a las bases de datos distribuidas de los registradores de dominios para obtener información sobre la asignación del nombre de host. Al tratarse de una técnica de reconocimiento pasivo, permite compilar inteligencia fundamental sin interactuar ni alertar a la infraestructura perimetral del objetivo.

```
(kali@kali)-[~] $ whois madridhifi.com
```

Resultado esperado y análisis técnico:

La ejecución del comando devuelve el registro:

- **Registrador (Registrar):** El activo digital se encuentra formalmente bajo la gestión técnica y tutela de la entidad OVH.
- **Fechas Clave del Activo:**
 - **Creation Date:** 1999-03-23T05:00:00Z (Valida una trayectoria sostenida y una infraestructura de marca consolidada de 27 años en el entorno digital).
 - **Updated Date:** 2026-03-24T08:01:52Z (Evidencia una modificación técnica o renovación automatizada reciente en los registros base del dominio).
 - **Registry Expiry Date:** 2027-03-23T04:00:00Z (Establece el límite temporal de vigencia para la concesión del dominio bajo el registrador actual).
- **Servidores de Nombres (Name Servers):** La resolución DNS autoritativa de las zonas del dominio está formalmente delegada a la infraestructura externa de la entidad *dunetechnology.com* a través de sus cuatro nodos redundantes (harkonnen, nostromo, sardaukar y scytale).

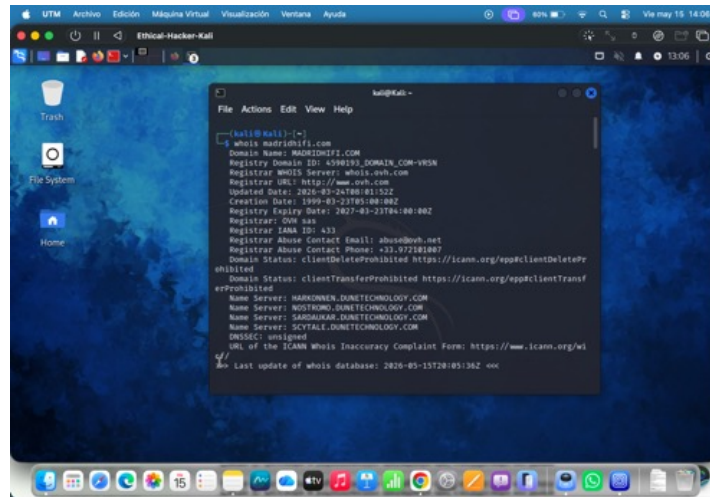


Ilustración 2. Whois consultas a bases de datos de los registradores de dominios

2.2.2 Reconocimiento de Infraestructura DNS mediante Dig

Se usó dig (*Domain Information Groper*) que es una herramienta de diagnóstico clave para evaluar los activos digitales y los riesgos de seguridad de la empresa de manera discreta.

(kali@kali)-[~]\$ dig madridhifi.com NS

Resultado obtenido:

La respuesta obtenida aporta datos e indicadores críticos sobre la delegación y la autoridad de resolución del dominio:

- **Sección de Pregunta (QUESTION SECTION):** Se verifica de manera que el objetivo de la consulta fue el dominio raíz *madridhifi.com*.
- **Sección de Respuesta (ANSWER SECTION):** Se verifica que el dominio está activo. Se valida la existencia de cuatro servidores de nombres independientes encargados de resolver las peticiones de zona del dominio, todos delegados bajo la entidad externa *dunetechnology.com*:
 - *nostromo.dunetechnology.com*.
 - *harkonnen.dunetechnology.com*.
 - *scytale.dunetechnology.com*.
 - *sardaukar.dunetechnology.com*.

Se verifica que se utiliza una estrategia de seguridad blindada en tres capas independientes: **Dune Technology** gestiona las direcciones oficiales de forma externa, **Cloudflare** actúa como un escudo en la nube que frena ciberataques antes de que nos alcancen, tal como se verá a continuación, y **OVH** almacena físicamente los datos de forma oculta y protegida.

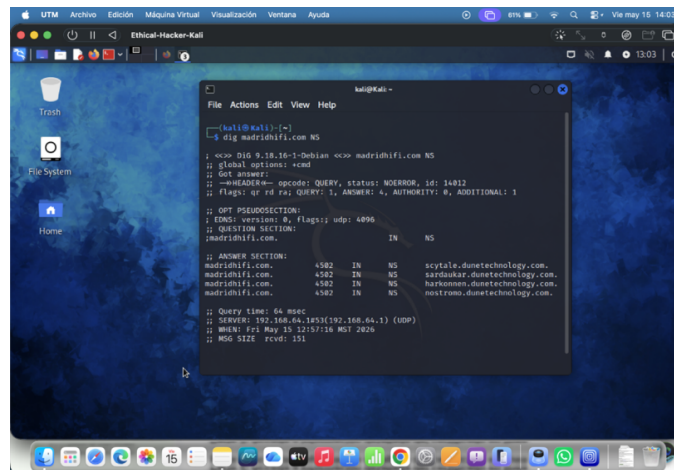


Ilustración 3.Consultas a los servidores de nombres DNS (Dig) Ilustración.

2.2.3. OWASP Amass (Enumeración de subdominios)

La herramienta **OWASP Amass** se utilizó en modo pasivo para buscar subdominios ocultos de la empresa a través de fuentes públicas de Internet. Este análisis permite mapear toda nuestra superficie de ataque expuesta e identificar activos olvidados o vulnerables antes de que un atacante los descubra.

```
(kali@kali)-[~] $ amass enum -passive -d madridhifi.com
```

```
(kali@kali)-[~] $ amass db -names -d madridhifi.com
```

Resultado obtenido:

La consulta a la base de datos de indexación arrojó un mapa detallado de subdominios que exponen la topología lógica, las herramientas de desarrollo y la arquitectura de operaciones de la organización:

- **Entornos de Desarrollo y Preproducción (Vectores de Alto Riesgo):** Se identificaron de manera pasiva activos como desarrollo.madridhifi.com, desarrollo-front.madridhifi.com, desarrollo-api.madridhifi.com, preproduccion.madridhifi.com y payments-test.api-preprod.madridhifi.com.
- **Gestión y Núcleo Corporativo:** El hallazgo del registro plesk.madridhifi.com delata la presencia del panel de control Plesk para la administración del servidor web, el cual podría ser un objetivo prioritario para ataques dirigidos de fuerza bruta.
- **Interfaces de Programación de Aplicaciones (APIs):** La localización de activos críticos como api.madridhifi.com, api-preprod.madridhifi.com y la pasarela de transacciones payments.api.madridhifi.com.
- **Arquitectura de Servidores y Comercio Electrónico:** Se listaron subdominios de control interno como server.madridhifi.com.

Se analiza que, aunque la web principal cuenta con el escudo de seguridad de Cloudflare, la exposición pública de plataformas críticas como Plesk y Dolibarr abre un vector de riesgo severo: un atacante podría descubrir la

dirección IP real del servidor y esquivar por completo las defensas perimetrales. Si se logra esto, los sistemas centrales y los datos de la empresa quedarían vulnerables a ataques directos, anulando la efectividad de la protección actual.

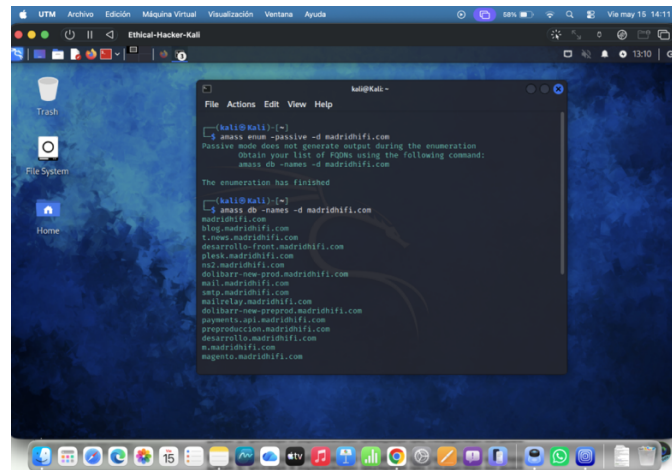


Ilustración 4. Enumeración de subdominios.

2.2.4. Fingerprinting y Detección de Tecnologías Perimetrales mediante WhatWeb

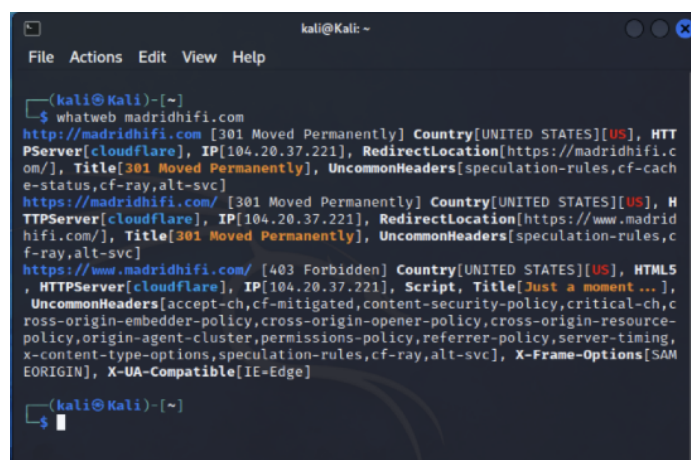
Se utilizó la herramienta **WhatWeb** para identificar automáticamente las tecnologías, software y lenguajes expuestos detrás de nuestra página web, permitiendo evaluar con precisión qué componentes internos están visibles al público y verificar la efectividad de la seguridad perimetral actual.

```
(kali@Kali)-[~] $ whatweb madridhifi.com
```

Resultado obtenido:

- **Bloqueo inmediato de amenazas:** El sistema de seguridad (**Cloudflare**) detectó el análisis automatizado como un posible ataque y lo bloqueó de inmediato (con un error 403 y la pantalla de verificación "Espera un momento...").
- **Escudo perimetral activo:** Se verificó que la web está oculta y protegida tras la infraestructura de Cloudflare.

Las defensas perimetrales están **activas y respondiendo correctamente**, bloqueando de forma automática cualquier intento de escaneo no autorizado.



```
kali@Kali: ~  
File Actions Edit View Help  
  
(kali@Kali)-[~]  
$ whatweb madridhifi.com  
http://madridhifi.com [301 Moved Permanently] Country[UNITED STATES][US], HTTPServer[cloudflare], IP[104.20.37.221], RedirectLocation[https://madridhifi.com/], Title[301 Moved Permanently], UncommonHeaders[speculation-rules,cf-cache-status,cf-ray,alt-svc]  
https://madridhifi.com/ [301 Moved Permanently] Country[UNITED STATES][US], HTTPServer[cloudflare], IP[104.20.37.221], RedirectLocation[https://www.madridhifi.com/], Title[301 Moved Permanently], UncommonHeaders[speculation-rules,cf-ray,alt-svc]  
https://www.madridhifi.com/ [403 Forbidden] Country[UNITED STATES][US], HTML5, HTTPServer[cloudflare], IP[104.20.37.221], Script, Title[Just a moment ...], UncommonHeaders[accept-ch,cf-mitigated,content-security-policy,critical-ch,cross-origin-embedder-policy,cross-origin-opener-policy,cross-origin-resource-policy,origin-agent-cluster,permissions-policy,referrer-policy,server-timing,x-content-type-options,speculation-rules,cf-ray,alt-svc], X-Frame-Options[SAMEORIGIN], X-UA-Compatible[IE=Edge]  
  
(kali@Kali)-[~]  
$
```

Ilustración 5. Identificación pasiva de tecnologías web (WHATWEB)

2.2.5. Estrategia de Validación de Infraestructura de Origen y Evasión del WAF (Triangulación de Evidencias)

Se verificó que los escaneos directos contra el dominio principal son bloqueados por el escudo de Cloudflare. Por ello, para avanzar de forma efectiva con la auditoría, **se verificó** la ubicación real del servidor de origen mediante una triangulación pasiva, asegurando así un análisis preciso sin alertar a los sistemas defensivos.

- **Fase 1: Análisis Inicial y Limitaciones del WHOIS de Red:** Durante el reconocimiento pasivo inicial, se identificó la dirección IP 149.202.105.250 asociada a la infraestructura de OVH. Las consultas WHOIS indicaron que dicha IP pertenece a un rango de servidores dedicados administrados por OVH.
- **Fase 2: Verificación mediante Búsqueda Inversa (Reverse IP Lookup):** Se ejecutó una consulta de *Reverse IP Lookup* (Búsqueda Inversa de IP) empleando la plataforma de inteligencia de amenazas *Hacker Target*. Los resultados arrojaron asociaciones exclusivas entre la dirección IP 149.202.105.250 y múltiples subdominios críticos pertenecientes a la raíz del objetivo, destacando interfaces posiblemente orientadas a producción, entornos de gestión interna y pasarelas transaccionales:
 - api.madridhifi.com
 - payments.api.madridhifi.com
 - dolibarr-new-prod.madridhifi.com

Este hallazgo técnico demostró una relación directa y dirigida entre la infraestructura física de OVH y la organización analizada, descartando la posibilidad de que se tratara de un servidor vecino o compartido por un tercero ajeno al objetivo.

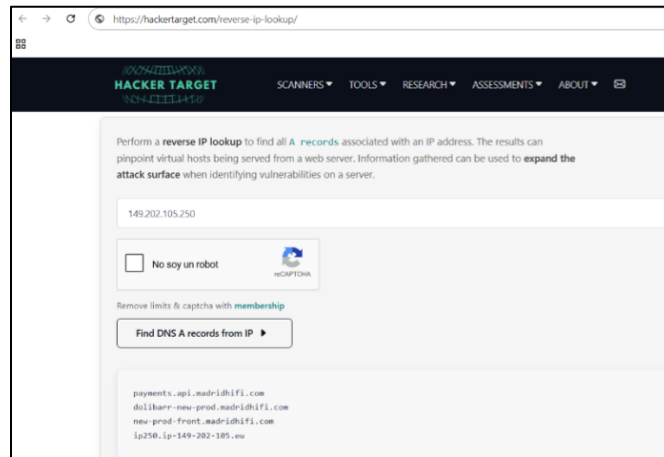


Ilustración 6. Reverse IP Lookup (hacker target)

- **Fase 3: Identificación de Fugas de Información por DNS (Bypass del WAF):** Se detectó una brecha crítica en la infraestructura, mientras la web principal está protegida por Cloudflare, múltiples subdominios apuntan directamente a la dirección IP real del servidor en OVH (149.202.105.250), dejando al descubierto la ubicación física. Se encuentra en **payments.api.madridhifi.com** (la posible plataforma que gestiona los pagos), al estar expuesta en Internet sin la protección del escudo perimetral, un atacante podría saltarse las defensas de la empresa y lanzar ataques directos contra el servidor central de operaciones y transacciones.
- **Fase 4: Validación de Autenticidad mediante Transparencia de Certificados (crt.sh):** Para garantizar que los subdominios expuestos están realmente activos y no son registros obsoletos, se auditó el registro público de certificados de seguridad (**Certificate Transparency**).

```

$ dig payments.api.madridhifi.com

<<>> DiG 9.20.20-1-Debian <<>> payments.api.madridhifi.com
; global options: +cmd
; Got answer:
; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 59007
; flags: qr rd ra; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 1

; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:;, udp: 1232
; QUESTION SECTION:
payments.api.madridhifi.com.      IN      A
; ANSWER SECTION:
payments.api.madridhifi.com. 3600 IN A      149.202.105.250

```

Ilustración 7. Bypass / Fuga DNS (Dig)

Certificate	Issued At	Not Before	Not After	Common Name	Matching Identifiers	Issuer Name
2020080801	2020-03-19	2020-03-19	2020-06-17	payments.api.madridhifi.com	C=US,O=Letsi Encrypt,CN=812	C=US,O=Letsi Encrypt,CN=812
2020080801	2020-03-19	2020-03-19	2020-06-17	payments.api.madridhifi.com	C=US,O=Letsi Encrypt,CN=812	C=US,O=Letsi Encrypt,CN=812
2020080801	2020-03-19	2020-03-19	2020-06-17	payments.api.madridhifi.com	C=US,O=Letsi Encrypt,CN=812	C=US,O=Letsi Encrypt,CN=812
2020080801	2020-03-19	2020-03-19	2020-06-17	payments.api.madridhifi.com	C=US,O=Letsi Encrypt,CN=812	C=US,O=Letsi Encrypt,CN=812
2020080801	2020-03-19	2020-03-19	2020-06-17	payments.api.madridhifi.com	C=US,O=Letsi Encrypt,CN=812	C=US,O=Letsi Encrypt,CN=812
2020080801	2020-03-19	2020-03-19	2020-06-17	payments.api.madridhifi.com	C=US,O=Letsi Encrypt,CN=812	C=US,O=Letsi Encrypt,CN=812
2020080801	2020-03-19	2020-03-19	2020-06-17	payments.api.madridhifi.com	C=US,O=Letsi Encrypt,CN=812	C=US,O=Letsi Encrypt,CN=812
2020080801	2020-03-19	2020-03-19	2020-06-17	payments.api.madridhifi.com	C=US,O=Letsi Encrypt,CN=812	C=US,O=Letsi Encrypt,CN=812
2020080801	2020-03-19	2020-03-19	2020-06-17	payments.api.madridhifi.com	C=US,O=Letsi Encrypt,CN=812	C=US,O=Letsi Encrypt,CN=812
2020080801	2020-03-19	2020-03-19	2020-06-17	payments.api.madridhifi.com	C=US,O=Letsi Encrypt,CN=812	C=US,O=Letsi Encrypt,CN=812

Ilustración 8. Validez temporal del ecosistema transaccional api y payments (crt.sh)

El análisis confirmó la emisión recurrente y vigente de certificados válidos para el subdominio **payments.api.madridhifi.com**. Al contar con cifrado activo, se concluye con total certeza que este canal representa la plataforma de pagos real y operativa de la empresa, validando que el riesgo de exposición hallado es real y requiere atención inmediata.

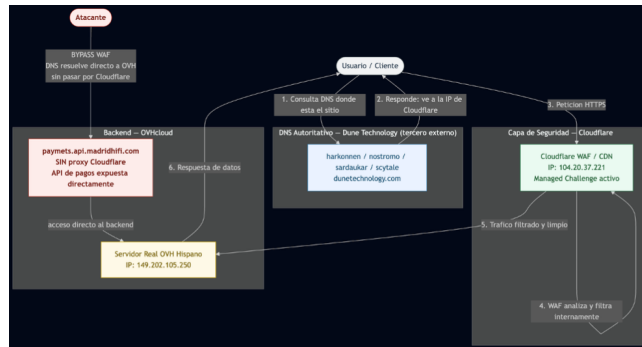


Ilustración 9. Superficie de ataque identificada

3. Personas y Redes Sociales (OSINT Orientada a Humanos)

Como el factor humano es uno de los vectores de riesgo más críticos, se realizó una investigación mediante fuentes públicas de Internet (**OSINT**) en dos fases: primero, se recopiló información de los empleados en redes como LinkedIn y el portal corporativo; segundo, se cruzaron estos datos para deducir el formato de los correos de la empresa y detectar información sensible expuesta. Esto permitió identificar debilidades que un atacante podría explotar para realizar fraudes, suplantaciones de identidad o ataques de ingeniería social.

3.1. Identificación de Datos Sensibles

3.1.1 Redes Sociales de la Empresa

La organización mantiene una presencia digital activa orientada a la promoción comercial a través de cuatro plataformas principales: un blog corporativo, YouTube, Instagram y la red profesional LinkedIn.

- **Instagram:** Cuenta con una comunidad de 214K seguidores y 214 perfiles seguidos, denotando un alto nivel de interacción de marca.
- **YouTube:** Registra un canal oficial con 27.6K suscriptores.
- **Ecosistema de Enlaces Identificados:**
 - *Blog Corporativo:* <https://blog.madridhifi.com/proel-grandes-soluciones-para-audio-profesional/>
 - *YouTube:* <https://www.youtube.com/@Madridhifi1>
 - *LinkedIn:* <https://www.linkedin.com/company/madrid-hifi/>

3.1.2 Plantilla y Estructura Organizacional

- **Razón Social:** La identidad corporativa y legal bajo la cual opera la organización corresponde a la entidad **Digital Audimagen Bq SL**.
- **Volumen de Personal:** De acuerdo con los registros comerciales y financieros consolidados de 2024, la empresa cuenta con una plantilla aproximada de 61 empleados.

- **Superficie de Exposición en Redes Profesionales:** De la plantilla total estimada, un total de 30 trabajadores (aproximadamente el 50% de la organización) poseen un perfil activo y visible en la red social profesional LinkedIn, vinculados directamente a la página de la compañía.



Ilustración 10. Estructura Organizacional de Madrid HiFi

3.1.3. Fugas de Información Técnica mediante Ingeniería Social Pasiva (Análisis de Perfiles Profesionales)

La revisión de fuentes abiertas en LinkedIn permitió identificar el perfil de **Elías Moreno Mata, Full Stack Developer / Arquitecto de APIs** en Madrid HiFi. La descripción explícita de sus funciones expone una fuga pasiva de información crítica sobre la infraestructura y el stack tecnológico real de la organización:

- **Arquitectura del Comercio Electrónico:** Se detalla un proceso de **migración activa desde un monorrepositorio en PHP hacia una arquitectura modular y desacoplada**, dividida de forma independiente en **API, Frontend y CRM**.
- **Ecosistema Backend y Datos:** Se confirma que el **core** actual opera bajo **Node.js y TypeScript**, utilizando **MariaDB** como base de datos gestionada a través de **Drizzle ORM**. Además, se revela la integración de la pasarela de pagos **Paycomet** y la lógica interna para gestionar carritos y pedidos.
- **Frontend y Entorno de Desarrollo:** El perfil expone el uso de **React y NextJS** en el *front*, así como las herramientas exactas de la cadena de desarrollo: documentación con **Swagger y Bruno**, testing con **Vitest** y despliegue automatizado en entornos **CI/CD**.

Esta exposición de datos facilita a un potencial atacante el mapeo preciso de la superficie de ataque y la identificación de tecnologías específicas para el diseño de *exploits* dirigidos.

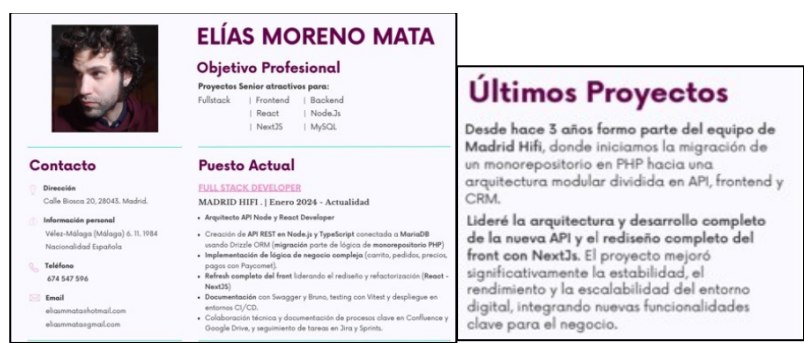


Ilustración 11. Fugas de Información Técnica mediante Ingeniería Social Pasiva

4. Conclusiones y Plan de Acción (Transición a la Fase Activa)

4.1. Síntesis del Reconocimiento Pasivo y Matriz de Validaciones

La finalización de la fase de reconocimiento pasivo ha permitido consolidar una visión general, precisa y libre de dudas sobre la infraestructura digital de la organización. Lejos de ser una acumulación de datos aislados, la auditoría se ejecutó bajo una metodología de triangulación técnica: cada hallazgo fue descubierto por una herramienta y rigurosamente validado por otra. Esto elimina la mayoría de falsos positivos y confirma la existencia de vectores de riesgo reales antes de iniciar la fase de intrusión activa.

La correlación de los resultados revela una posible brecha estructural de severidad Crítica con una topología de seguridad asimétrica. Mientras que el dominio principal (madridhifi.com) se encuentra correctamente protegido tras el escudo perimetral de Cloudflare, parece que la organización sufre de fugas de información críticas. Subdominios posiblemente de alta sensibilidad (como la API de procesamiento de pagos payments.api.madridhifi.com, los entornos de producción del ERP Dolibarr y los paneles de control Plesk) apuntan de forma directa hacia la dirección IP física de los servidores dedicados en OVH (149.202.105.250), esquivando por completo el filtro de seguridad (WAF).

Tabla 1. Matriz de Validación del Reconocimiento Pasivo

Herramienta / Técnica	Propósito técnico	Hallazgo validado	Criticidad
OSINT Framework + Website Informer	Centralización de datos de registro, infraestructura y tráfico.	Cloudflare como capa perimetral (CIDR 104.16.0.0/12), OVH SAS como registrador (IANA 433) y proveedor de hosting físico (IP 149.202.105.250), 10.6K visitantes diarios (fuente única — website.informer), presencia de Cookiebot/RGPD.	Media
WHOIS (whois madridhifi.com)	Identificación de registrador, fechas de vigencia y estados EPP.	OVH SAS (IANA ID: 433) como registrador del dominio, creación 1999-03-23, expiración 2027-03-23, estados clientDeleteProhibited y clientTransferProhibited, delegación DNS a dunetechnology.com.	Media
DNS Mapping (dig NS)	Verificación de servidores autoritativos de zona y propagación activa.	4 nameservers bajo dunetechnology.com (harkonnen, nostromo, sardaukar, scytale), status NOERROR, TTL 4502s.	Media
OWASP Amass (modo pasivo)	Enumeración de subdominios mediante OSINT y CT logs.	Subdominios críticos: entornos de desarrollo, plesk, dolibarr (new/prod/preprod), api, payments.api, magento, infraestructura de correo completa.	Alta
WhatWeb (fingerprinting)	Identificación de tecnologías perimetrales y comportamiento WAF.	Respuesta 403 Forbidden + JS Challenge de Cloudflare, IP frontal 104.20.37.221 (identificada en fase OSINT Framework, no por WhatWeb directamente), cabeceras cf-mitigated, CSP, X-Frame-Options.	Alta

Reverse IP Lookup (hackertarget.com)	Verificación de exclusividad del servidor de origen.	IP 149.202.105.250 vinculada exclusivamente a subdominios críticos de madridhifi.com (api, payments.api, dolibarr-new-prod, new-prod-front), confirmando que exponen el servidor de origen directamente sin protección WAF.	Crítica
DNS directo / dig A record	Confirmación de resolución directa sin proxy WAF.	payments.api.madridhifi.com resuelve a 149.202.105.250 sin intermediación de Cloudflare (NOERROR, TTL 3600). Bypass del WAF confirmado de forma técnica.	Crítica
Certificate Transparency (crt.sh)	Validación de autenticidad y vigencia de activos expuestos.	Certificados SSL/TLS vigentes emitidos por Let's Encrypt R13, expiración 2026-06-17. Confirma que payments.api.madridhifi.com es una pasarela de pagos activa en producción, validando que el riesgo de exposición es real e inmediato.	Crítica
OSINT Humano (LinkedIn / perfiles)	Ingeniería social pasiva para extracción de inventario tecnológico.	Stack tecnológico expuesto por perfil de empleado (fuente única — pendiente validación cruzada): Node.js, TypeScript, MariaDB (Drizzle ORM), React, NextJS, Paycomet, CI/CD, APIs REST. 30 de 61 empleados identificados con nombres y roles. Nota: Dolibarr ERP fue identificado por OWASP Amass, no por esta fuente.	Crítica

4.2. Plan de Acción Estratégico y Vectores de Explotación

La convergencia de los cuatro vectores con el inventario tecnológico obtenido de forma completamente pasiva configura un escenario en el que la fase activa se inicia con un nivel de inteligencia previa equivalente al de un atacante con conocimiento interno de la organización. El WAF de Cloudflare resulta operativamente irrelevante, los escaneos se ejecutarán sobre la IP directa de OVH, los subdominios transaccionales son accesibles sin intermediación y el stack tecnológico completo ha sido identificado sin haber generado una sola alerta en los sistemas defensivos del objetivo durante toda la fase pasiva.

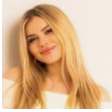
Tabla 2. Matriz de Ejecución y Plan de Acción

Vector	Estrategia operativa en fase activa
Vector 1 Escaneo directo de infraestructura	Nmap con scripts NSE selectivos sobre servicios confirmados por OSINT: - Puertos 80/443 (HTTP/S): servidor web de origen (Apache/Nginx). - Puerto 3306/TCP: MariaDB, confirmado por perfil LinkedIn de Elías Moreno Mata.
Vector 2 Bypass WAF / subdominios expuestos	Frente 1 — ERP Dolibarr (PHP): - Análisis de fallos de autorización rota (IDOR) y control de acceso a nivel de objeto. - Búsqueda de endpoints no documentados en la interfaz de gestión interna. Frente 2 — API de Pagos (Node.js / TypeScript / Drizzle ORM / Paycomet): - Inyección lógica sobre endpoints transaccionales (carritos, pedidos, pagos). - Corrupción de prototipos en JavaScript (prototype pollution). - Verificación de control de acceso a nivel de objeto (IDOR) en operaciones transaccionales. - Enumeración de endpoints no documentados a través de la especificación Swagger (expuesta pasivamente).
Vector 3 Fuzzing de API REST y análisis de hardening del framework	Sobre la API REST (Node.js / TypeScript / Drizzle ORM): - Enumeración de endpoints a través de la interfaz Swagger/Bruno expuesta pasivamente (/swagger, /api-docs, /openapi.json). - Directory busting sobre rutas estandarizadas de APIs REST (/api/v1/, /api/v2/). - Análisis de inyecciones en el ORM Drizzle sobre endpoints de consulta y modificación de datos. - Verificación de controles de autenticación en entornos de preproducción (api-preprod, payments-test), que habitualmente presentan hardening inferior al entorno de producción. Sobre el subdominio magento.madridhifi.com (pendiente de validación): - Si la fase activa confirma actividad, se ejecutará directory busting sobre /admin, /backend, /rest/v1/ y verificación de CVEs de deserialización específicos de Magento 2.
Vector 4 Enumeración de identidades y fuerza bruta dirigida	Construcción de diccionario estructurado de usuarios aplicando ambos patrones de formato de correo sobre los 30 empleados identificados. Pruebas de credential stuffing y fuerza bruta de bajo perfil contra: - Plesk (panel de administración del servidor). - Dolibarr ERP/CRM (interfaz de gestión interna). - Endpoints de autenticación de la API REST expuesta en la IP de OVH. La ausencia de WAF sobre la IP de origen elimina controles de rate limiting y bloqueo por intentos fallidos, maximizando la viabilidad del vector.

ANEXO 1. Tablas

Tabla 3. Personal y Estructura Organizacional

Departamento	Trabajador	Email	Redes sociales	Puesto	Otros datos
Dirección	Jorge Rojas Dorado	jorge@madridhifi.com	https://www.instagram.com/rugerio5/	CEO	
	Joaquin Rojas Altares			Presidente	
	Mariano Rojas Altares	mariano.rojas@madridhifi.com		Director gerente	
	Manuel Picón Serrano 			CFO	
	Ramón Macías Hernan 			COO	
Departamento RRHH	Maria Rojas	maria.rojas@madridhifi.com			
Departamento Comercial	Lorena Ortiz Godoy 			Head of customer support	
	Marcos Cano Guerrero 		Link instagram	customer support	
	Juan Antonio Rivilla Losada 			Especialista en ventas	
	Jose Antonio (Tote) Blanco Zea 		@totebz94 instagram	Especialista en ventas, asesoramiento al cliente	Le sigue Marcos cano Guerrero en instagram
	Nicolas Valle Michelow 				
	Fernando R			Director	

Departamento Marketing	Sergio Masip Secos 			Director	
	José Sanchez Liberato 		Instagram joseliberato ?	Especialista en marketing digital	
	Lucia Perez Vin del 			Junior	
	Marta Garcia Saez 		Instagram maarta._garciaa		
	Carlos Prados Zamora 			Especialista en guitarras	
Departamento Compras	Javier Garza 	javier.garza@madridhifi.com			
Departamento Importación	Simona Monteau 			Inside sales	
Departamento IT	Franco Torres			Responsable	
	Manuel Jiménez Liebana				Experiencia en programación en Android
	Alfredo Fernández Hernández		Link linkedin		
	Pablo Elias Moreno Mata 		Link github Instagram: @eliasmmata	Desarrollador	Link CV
	Mario A 			Web developer	
Otros	Marina S			Technical Support Music Production	
	Manuel Campos			Product manager sonido	

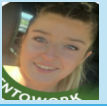
					
	Pablo Peláez Ballesteros 			Especialista en guitarras, pedales y amplificadores	
	Alfonso Rojas Fernandez 				
	Idoia Garcia 			Administrativo	
	Gonzalo M				
	Jesus Ruiz Orihuela 			Administrativo	
	Alfredo Ortiz Quinatana 			Mozo de almacén	
	Noelia López Ramos 				
	Levin Ocaña Vázquez 			músico	Link instagram

Tabla 4. Matriz de Ejecución y Plan de Acción (Vectores)

Vector	Objetivo validado pasivamente	Estrategia operativa en fase activa
Vector 1 Escaneo directo de infraestructura	IP 149.202.105.250 (OVH SAS) Validada por cuatro fuentes independientes: • WHOIS: IP asociada a OVH SAS como proveedor de hosting físico. • Reverse IP Lookup (HackerTarget): IP vinculada exclusivamente a subdominios de madridhifi.com (api, payments.api, dolibarr-new-prod). • dig A record: payments.api.madridhifi.com resuelve a 149.202.105.250 con estado NOERROR y TTL 3600, sin intermediación de Cloudflare. • crt.sh: certificado SSL/TLS vigente emitido por Let's Encrypt R13, expiración 2026-06-17, confirmando actividad en producción.	Nmap con scripts NSE selectivos sobre servicios confirmados por OSINT: • Puertos 80/443 (HTTP/S): servidor web de origen (Apache/Nginx). • Puerto 3306/TCP: MariaDB, confirmado por perfil LinkedIn de Elías Moreno Mata.
Vector 2 Bypass WAF / subdominios expuestos	payments.api.madridhifi.com y dolibarr-new-prod.madridhifi.com Ambos resuelven directamente a 149.202.105.250 sin pasar por Cloudflare, confirmado por dig A record (NOERROR, TTL	Frente 1 — ERP Dolibarr (PHP): • Análisis de fallos de autorización rota (IDOR) y control de

	3600) y crt.sh. Sin JS Challenge, rate limiting ni inspección WAF. Dos superficies diferenciadas sobre el mismo servidor: • dolibarr-new-prod.madridhifi.com: núcleo ERP/CRM (PHP). • payments.api.madridhifi.com: pasarela transaccional REST en Node.js / TypeScript con Drizzle ORM e integración Paycomet. Gestiona carritos, pedidos y flujos de pago.	acceso a nivel de objeto. • Búsqueda de endpoints no documentados en la interfaz de gestión interna. Frente 2 — API de Pagos (Node.js / TypeScript / Drizzle ORM / Paycomet): • Inyección lógica sobre endpoints transaccionales (carritos, pedidos, pagos). • Corrupción de prototipos en JavaScript (prototype pollution). • Verificación de control de acceso a nivel de objeto (IDOR) en operaciones transaccionales. • Enumeración de endpoints no documentados a través de la especificación Swagger (expuesta pasivamente).
Vector 3 Fuzzing de API REST y análisis de hardening del framework	API REST en Node.js / TypeScript con Drizzle ORM Confirmada por OSINT humano (perfil LinkedIn — Elías Moreno Mata). El perfil expone: • Arquitectura modular dividida en API, Frontend y CRM, migrada desde monorrepositorio PHP. • Documentación de la API generada con Swagger y Bruno (posible exposición de endpoints en /swagger o /api-docs). • Testing con Vitest y despliegue en entornos CI/CD (presencia de entornos preproducción confirmada por Amass: api-preprod, payments-test.api-preprod).	Sobre la API REST (Node.js / TypeScript / Drizzle ORM): • Enumeración de endpoints a través de la interfaz Swagger/Bruno expuesta pasivamente (/swagger, /api-docs, /openapi.json). • Directory busting sobre rutas estandarizadas de APIs REST (/api/v1/, /api/v2/). • Análisis de inyecciones en el ORM Drizzle sobre endpoints de consulta y modificación de datos. • Verificación de controles de autenticación en entornos de preproducción (api-preprod, payments-test), que habitualmente presentan hardening inferior al entorno de producción. Sobre el subdominio magento.madridhifi.com (pendiente de validación): • Si la fase activa confirma actividad, se ejecutará directory busting sobre /admin, /backend, /rest/V1/ y verificación de CVEs de deserialización específicos de Magento 2.
Vector 4 Enumeración de identidades y fuerza bruta dirigida	30 de 61 empleados identificados en LinkedIn con nombre, apellido y rol. Dos patrones de correo corporativo inferidos a partir de direcciones confirmadas: • Patrón A nombre@madridhifi.com (ej. jorge@madridhifi.com) • Patrón B nombre.apellido@madridhifi.com (ej. mariano.rojas@madridhifi.com, maria.rojas@madridhifi.com, javier.garza@madridhifi.com) Paneles de autenticación expuestos directamente sobre la IP de OVH sin protección perimetral: Plesk, Dolibarr y API REST (documentación Swagger).	Construcción de diccionario estructurado de usuarios aplicando ambos patrones de formato de correo sobre los 30 empleados identificados. Pruebas de credential stuffing y fuerza bruta de bajo perfil contra: • Plesk (panel de administración del servidor). • Dolibarr ERP/CRM (interfaz de gestión interna). • Endpoints de autenticación de la API REST expuesta en la IP de OVH. La ausencia de WAF sobre la IP de origen elimina controles de rate limiting y bloqueo por intentos fallidos, maximizando la viabilidad del vector.

5. Bibliografía

Cloudflare, Inc. (s.f.). Cloudflare: The web performance & security company.

<https://www.cloudflare.com/>

Cookiebot (Usercentrics). (s.f.). Cookiebot CMP: Cookie consent and compliance solution. <https://www.cookiebot.com/>

crt.sh. (s.f.). crt.sh | Certificate Search. Sectigo Limited.

<https://crt.sh/>

HackerTarget. (s.f.). Reverse IP Lookup.

<https://hackertarget.com/reverse-ip-lookup/>

Harrison, S. (2004). WHOIS Protocol Specification (RFC 3912). Internet Engineering Task Force.

<https://www.rfc-editor.org/rfc/rfc3912>

Internet Systems Consortium (ISC). (s.f.). dig(1) — BIND 9 Administrator Reference Manual.

<https://bind9.readthedocs.io/en/latest/manpages.html#dig>

LinkedIn Corporation. (s.f.). LinkedIn.

<https://www.linkedin.com/>

Madrid HiFi. (s.f.). Madrid HiFi [Sitio web corporativo].

<https://madridhifi.com/>

Nordine, J. (s.f.). OSINT Framework.

<https://osintframework.com/>

OWASP Foundation. (s.f.). OWASP Amass Project.

<https://owasp.org/www-project-amass/>

urbanadventurer (Horton, A.) y Coles, B. (s.f.). WhatWeb: Next generation web scanner [Software]. GitHub.

<https://github.com/urbanadventurer/WhatWeb>

Website Informer. (s.f.). Website Informer: Website research and analytics tool.

<https://website.informer.com/>